



Australian Signals Directorate Essential Eight

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer.....	4
Version.....	5
Introduction.....	5
Third Party Identifiers and Mappings	5
Coverage Levels	5
Controls.....	6
Control ML1-P1	6
Control ML1-P2	11
Control ML1-P3	16
Control ML1-P4	17
Control ML1-P5	24
Control ML1-P6	28
Control ML1-P7	34
Control ML1-P8	40
Control ML2-P1	46
Control ML2-P2	51
Control ML2-P3	56
Control ML2-P4	61
Control ML2-P5	66
Control ML2-P6	72
Control ML2-P7	78
Control ML2-P8	84
Control ML3-P1	90
Control ML3-P2	95
Control ML3-P3	100
Control ML3-P4	105
Control ML3-P5	111
Control ML3-P6	117
Control ML3-P7	123
Control ML3-P8	129

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the Australian Signals Directorate Essential Eight. The Essential Eight, published by the Australian Signals Directorate (ASD), is a set of prioritised mitigation strategies: patch applications, patch operating systems, multi-factor authentication, restrict administrative privileges, application control, restrict Microsoft Office macros, user application hardening, and regular backups. Each strategy is assessed at three maturity levels. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for implementing and assessing the mitigation strategies remains with the organisation.

<https://www.cyber.gov.au/resources-business-and-government/essential-cybersecurity/essential-eight>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control ML1-P1

> Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an asset_id field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an se_group_refs parameter to target a specific Service Engine group for patching; when se_group_refs is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML1-P2

> Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected

attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources

discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML1-P3

> Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are.

SCF Controls: IAC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P4

> Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Privileged users use separate privileged and unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments.

SCF Controls: IAC-08, IAC-16, IAC-16.4, IAC-21, IAC-21.2, IAC-21.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create

entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-

program access privileges on Linux nodes. When `requirePasswordOnSudo` is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The `vmware-system-restricted` Pod Security Policy, applied through `RoleBindings`, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via `RoleBinding` to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the `authorizedGroups` field of the `PAISConfiguration` custom resource when activating Private AI Services in an organization namespace through `kubectl`, or through the `oidc-authorized-groups` setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as `group-for-pais-access-01` or `group-for-pais-access-02`, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including `L4POLICYSET`, `WAFPOLICYPSMGROUP`, `PINGACCESSAGENT`, `NETWORKSERVICE`, and `NATPOLICY`, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Control ML1-P5

> Application control: Application control is implemented on workstations. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients. Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set.

SCF Controls: CFG-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before

admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the `module_request` permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a RuntimeDefault seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes NetworkPolicy resources provide a namespace-level deny-by-default network posture: a NetworkPolicy that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The DenyServiceExternalIPs admission controller restricts Service resources from using LoadBalancer types or ExternalIPs fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support SecurityPolicies instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend (DFW) contributes to application access control at the network layer through explicit allowlist and denylist enforcement on workload traffic flows. DFW rules support four actions: Allow, Block, Reject, or Jump To Application. A default-deny posture drops all traffic not explicitly allowed, protecting application groups from unauthorized communication.

The 9.1 DFW Application Connectivity Strategy provides structured policy templates for common allowlist and denylist postures. The Allow Intra, Deny Other Traffic strategy generates an intra-group ALLOW rule using the ALLOW_INTRA and ALLOWLIST APIs plus a default ANY/ANY/DROP rule, enforcing strict isolation for application groups. The Allow Outbound, Deny Other Traffic strategy generates a specific egress ALLOW rule (application group to any) plus a default DROP rule, permitting only authorized outbound communication. The Deny List strategy allows all traffic by default with optional logging, supporting environments where observed-traffic baselining is the initial posture. ALLOW EGRESS rules can be individually configured with Allow or Drop actions to control whether application entities may initiate external communication. Centralized Transit Gateway Firewall rules can enforce inter-project isolation by denying all inter-project communication except designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

Identity Firewall supports user identity-based access controls with Allow and Reject actions for specified user groups, services, and destinations, extending allowlist and denylist enforcement to user context through Active Directory integration.

Security Services Platform Application Protection in Strict Mode enforces application-level firewall rules across all workloads except infrastructure, with coverage scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence recommends granular application-level rules that allow only authorized traffic between environment pairs, helping administrators build explicit allowlist policy from observed flows.

Host-level application execution controls, such as OS-level application allowlisting (AppLocker, SELinux), are outside vDefend's scope and must be addressed by endpoint security tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as IptoCountryCode available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with Is and Is Not operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault` seccomp profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P6

> Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-

standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML1-P7

> User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browser security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-

standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML1-P8

> Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Unprivileged user accounts are prevented from modifying and deleting backups.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware

vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For

on-demand backups outside a scheduled window, the velero backup create command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes.

Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control ML2-P1

> Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release. Patches, updates or other vendor mitigations for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within one month of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization,

capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the

organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an asset_id field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML2-P2

> Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected

attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources

discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML2-P3

> Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication is used to authenticate privileged users of systems. Multi-factor authentication is used to authenticate unprivileged users of systems. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are. Multi-factor authentication used for authenticating users of online services is phishing-resistant. Multi-factor authentication used for authenticating customers of online customer services provides a phishing-resistant option. Multi-factor authentication used for authenticating users of systems is phishing-resistant. Successful and unsuccessful multi-factor authentication events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: IAC-06, IAC-06.2, IAC-06.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings

consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute,

supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including `SERVER_HEALTH_DEGRADED`, `POOL_HEALTH_DEGRADED`, and `VS_UP`. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control ML2-P4

> Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged access to systems, applications and data repositories is disabled after 12 months unless revalidated. Privileged access to systems and applications is disabled after 45 days of inactivity. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Privileged users use separate privileged and unprivileged operating environments. Privileged operating environments are not virtualised within unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments. Administrative activities are conducted through jump servers. Credentials for break glass accounts, local administrator accounts and service accounts are long, unique, unpredictable and managed. Privileged access events are centrally logged. Privileged user account and security group management events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: AST-27, IAC-08, IAC-15.3, IAC-15.9, IAC-16, IAC-16.4, IAC-21, IAC-21.2, IAC-21.3, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17, SEA-22

Aggregate Coverage: Meets

VCF (Meets)

VCF provides account deactivation capabilities across its management components, but does not include a built-in automated mechanism to detect and disable accounts based on inactivity duration. The manual deactivation features across the platform supply the technical foundation that an organization can build upon to satisfy this control when paired with external identity governance processes or tooling.

NSX Manager ships with three default inactive local user accounts (audit, guestuser1, and guestuser2), which can be deleted, activated, or deactivated through the Local Users tab in the NSX Manager UI. The admin user or any user with the Enterprise Admin role can activate or deactivate any local user account except for the built-in admin account, which cannot be deactivated.

VMware vCenter supports account deactivation at both the VCF SSO and local user account levels. VCF SSO user accounts can be deactivated through the vCenter management interface; a deactivated account remains in the identity store but the user cannot log in until an administrator reactivates it. For vCenter local user accounts managed through the Appliance Shell, administrators can use the ``localaccounts.user.set --username <username> --status disabled`` command to disable a specific account, or restore access by setting the status back to enabled.

VCF Operations provides account activation and deactivation controls. Administrators can deactivate user accounts through the Activated field or a disable checkbox, which stops the user from accessing VCF Operations features. The account can be reactivated later if needed.

VCF Automation provides similar capabilities at both the user and user group level. Organization administrators can disable users, which deactivates their access to the organization and stops them from logging in. Provider-level users can also be deactivated, after which the user cannot log in to VCF Automation. Disabling a user in VCF Automation does not remove them from the organization, and their access can be reactivated at a later time. User accounts can also be deleted entirely when no longer required.

For service accounts, VCF implements automatic token expiration as a form of time-bound access control. Service accounts authenticate using API access tokens that rotate after each use. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days. Refresh tokens can be revoked earlier and optionally rotated with each access token request. This token lifecycle provides an automated mechanism that limits the duration of service account access without manual intervention.

Within the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide automated mechanisms for managing service account credential lifetimes. The Kubernetes control plane includes the LegacyServiceAccountTokenCleanup feature gate, which enables automatic purging of Secret-based service account tokens that have not been used within a configurable inactivity period. The inactivity window is set through the `--legacy-service-account-token-clean-up-period` flag on the kube-controller-manager, configurable via the `LegacySATokenCleanerConfiguration.CleanUpPeriod` field; the default retention period is one year. The companion LegacyServiceAccountTokenTracking feature marks unused auto-generated tokens as invalid when they are not mounted by any pods and have remained unused for the configured period, at which point the cleanup controller removes them. For workloads using projected service account tokens, the `projected.sources.serviceAccountToken.expirationSeconds` parameter sets a bounded validity window for each token, limiting its active lifetime regardless of usage patterns; organizations should prefer short-lived projected tokens over long-lived Secret-based tokens. For human user access to VKS clusters, VCF SSO is the default authentication backend and can integrate with Active Directory and LDAP systems; inactivity-based account disabling for human users is enforced at the identity provider level and flows through VCF SSO into the VKS authentication layer.

VMware ESX hosts provide time-based access controls for ESX Shell access. The ESX Shell availability timeout can be configured so that the service deactivates and prevents new logins after a specified period, and the idle timeout setting automatically logs out users from inactive interactive sessions. These settings limit the duration of shell access when manual deactivation has not been performed.

To fully satisfy this control, organizations should integrate VCF's identity sources with an external identity provider such as Active Directory, LDAP, or an OIDC provider that supports automated detection of inactive accounts and time-based disabling policies. VCF's local account deactivation features can then be used to enforce disabling actions identified by the external governance process, giving administrators the ability to respond to specific account management needs directly within the platform.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when

needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to

other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has `sudo` privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including `L4POLICYSET`, `WAFPOLICYPSMGROUP`, `PINGACCESSAGENT`, `NETWORKSERVICE`, and `NATPOLICY`, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Control ML2-P5

> Application control: Application control is implemented on workstations. Application control is implemented on internet-facing servers. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients. Application control is applied to all locations other than user profiles and temporary folders used by operating systems, web browsers and email clients. Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set. Microsoft's recommended application blacklist is implemented. Application control rulesets are validated on an annual or more frequent basis. Allowed and blocked application control events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, CFG-02.1, CFG-03.2, CFG-03.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated

and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the `ClusterClass` API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that

cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML2-P6

> Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macros are blocked from making Win32 API calls. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure.

components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML2-P7

> User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browsers are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Web browser security settings cannot be changed by users. Microsoft Office is blocked from creating child processes. Microsoft Office is blocked from creating executable content. Microsoft Office is blocked from injecting code into other processes. Microsoft Office is configured to prevent activation of Object Linking and Embedding packages. Office productivity suites are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Office productivity suite security settings cannot be changed by users. PDF software is blocked from creating child processes. PDF software is hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. PDF software security settings cannot be changed by users. PowerShell module logging, script block logging and transcription events are centrally logged. Command line process creation events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, IRO-02, IRO-10, MON-02.2, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that

defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The podSecurityStandard field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including kube-system, pkg-system, and vmware-system-cloudprovider are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. seccomp restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the RuntimeDefault seccomp profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the PAISConfiguration custom resource. Private AI Services settings are declared in a YAML file compliant with the PAISConfiguration schema and applied with kubectl, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the

spec.observability.prometheusRuntime section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an ILMTraces section for routing large language model traces to an OpenTelemetry Collector. The PAISConfiguration custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the spec.clientTls.caBundleRefs section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the authorizedGroups setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through SupervisorNamespaceClassConfig, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property config-json accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through export_dcgm_to_public and JupyterLab authentication through enable_jupyter_auth, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an

Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure

infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML2-P8

> Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Privileged user accounts (excluding backup administrator accounts) cannot access backups belonging to other user accounts. Unprivileged user accounts are prevented from modifying and deleting backups. Privileged user accounts (excluding backup administrator accounts) are prevented from modifying and deleting backups.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats

with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The `CloneFromSnapshot` CRD includes a `status.phase` field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in `etcdctl snapshot save` command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During `kubeadm` upgrades, automatic backup folders are written to `/etc/kubernetes/tmp` containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the `RecoveryBackupJobBackupRequest` data structure for specifying backup location, protocol, authorization, and database scope, as well as the `RecoveryBackupSchedulesUpdateSpec` for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups

during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the export command), or REST API (using the /api/scheduler/ endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the keep_uuid option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control ML3-P1

> Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within one month of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed. Applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The RetrievePropertiesEx method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom

object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of

granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an asset_id field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an se_group_refs parameter to target a specific Service Engine group for patching; when se_group_refs

is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML3-P2

> Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in drivers. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in firmware. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. The latest release, or the previous release, of operating systems are used. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, SEA-07.1, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or

Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting

access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML3-P3

> Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication is used to authenticate privileged users of systems. Multi-factor authentication is used to authenticate unprivileged users of systems. Multi-factor authentication is used to authenticate users of data repositories. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are. Multi-factor authentication used for authenticating users of online services is phishing-resistant. Multi-factor authentication used for authenticating customers of online customer services is phishing-resistant. Multi-factor authentication used for authenticating users of systems is phishing-resistant. Multi-factor authentication used for authenticating users of data repositories is phishing-resistant. Successful and unsuccessful multi-factor authentication events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from non-internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from workstations are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: IAC-06, IAC-06.2, IAC-06.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to

add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict,

and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action,

using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including `SERVER_HEALTH_DEGRADED`, `POOL_HEALTH_DEGRADED`, and `VS_UP`. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control ML3-P4

> Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged access to systems, applications and data repositories is disabled after 12 months unless revalidated. Privileged access to systems and applications is disabled after 45 days of inactivity. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged access to systems, applications and data repositories is limited to only what is required for users and services to undertake their duties. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Secure Admin Workstations are used in the performance of administrative activities. Privileged users use separate privileged and unprivileged operating environments. Privileged operating environments are not virtualised within unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments. Just-in-time administration is used for administering systems and applications. Administrative activities are conducted through jump servers. Credentials for break glass accounts, local administrator accounts and service accounts are long, unique, unpredictable and managed. Memory integrity functionality is enabled. Local Security Authority protection functionality is enabled. Credential Guard functionality is enabled. Remote Credential Guard functionality is enabled. Privileged access events are centrally logged. Privileged user account and security group management events are centrally logged. Event logs are protected from unauthorised modification and deletion.

SCF Controls: AST-27, CFG-02, IAC-08, IAC-15.3, IAC-15.9, IAC-16, IAC-16.4, IAC-20.4, IAC-21, IAC-21.2, IAC-21.3, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17, SEA-22

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The podSecurityStandard field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including kube-system, pkg-system, and vmware-system-cloudprovider are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. seccomp restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the RuntimeDefault seccomp profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the PAISConfiguration custom resource. Private AI Services settings are declared in a YAML file compliant with the PAISConfiguration schema and applied with kubectl, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the spec.observability.prometheusRuntime section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an llmTraces section for routing large language model traces to an OpenTelemetry Collector. The PAISConfiguration custom resource can be patched with kubectl patch and verified with kubectl get paisconfiguration, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the spec.clientTls.caBundleRefs section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the authorizedGroups setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through SupervisorNamespaceClassConfig, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property config-json accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through export_dcgm_to_public and JupyterLab authentication through enable_jupyter_auth, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML3-P5

> Application control: Application control is implemented on workstations. Application control is implemented on internet-facing servers. Application control is implemented on non-internet-facing servers. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients. Application control is applied to all locations other than user profiles and temporary folders used by operating systems, web browsers and email clients. Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set. Application control restricts the execution of drivers to an organisation-approved set. Microsoft's recommended application blocklist is implemented. Microsoft's vulnerable driver blocklist is implemented. Application control rulesets are validated on an annual or more frequent basis. Allowed and blocked application control events are centrally logged. Event logs are protected from unauthorised modification and deletion.

SCF Controls: CFG-02, CFG-02.1, CFG-03.2, CFG-03.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKrs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per

application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database

instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application

security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML3-P6

> Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Only Microsoft Office macros running from within a sandboxed environment, a Trusted Location or that are digitally signed by a trusted publisher are allowed to execute. Microsoft Office macros are checked to ensure they are free of malicious code before being digitally signed or placed within Trusted Locations. Only privileged users responsible for checking that Microsoft Office macros are free of malicious code can write to and modify content within Trusted Locations. Microsoft Office macros digitally signed by an untrusted publisher cannot be enabled via the Message Bar or Backstage View. Microsoft Office macros digitally signed by signatures other than V3 signatures cannot be enabled via the Message Bar or Backstage View. Microsoft Office's list of trusted publishers is validated on an annual or more frequent basis. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macros are blocked from making Win32 API calls. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02, CFG-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKrs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per

application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database

instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application

security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML3-P7

> User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browsers are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Web browser security settings cannot be changed by users. Microsoft Office is blocked from creating child processes. Microsoft Office is blocked from creating executable content. Microsoft Office is blocked from injecting code into other processes. Microsoft Office is configured to prevent activation of Object Linking and Embedding packages. Office productivity suites are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Office productivity suite security settings cannot be changed by users. PDF software is blocked from creating child processes. PDF software is hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. PDF software security settings cannot be changed by users. .NET Framework 3.5 (includes .NET 2.0 and 3.0) is disabled or removed. Windows PowerShell 2.0 is disabled or removed. PowerShell is configured to use Constrained Language Mode. PowerShell module logging, script block logging and transcription events are centrally logged. Command line process creation events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from non-internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from workstations are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The podSecurityStandard field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including kube-system, pkg-system, and vmware-system-cloudprovider are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. seccomp restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the RuntimeDefault seccomp profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the PAISConfiguration custom resource. Private AI Services settings are declared in a YAML file compliant with the PAISConfiguration schema and applied with kubectl, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the spec.observability.prometheusRuntime section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an llmTraces section for routing large language model traces to an OpenTelemetry Collector. The PAISConfiguration custom resource can be patched with kubectl patch and verified with kubectl get paisconfiguration, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the spec.clientTls.caBundleRefs section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the authorizedGroups setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through SupervisorNamespaceClassConfig, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property config-json accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through export_dcgm_to_public and JupyterLab authentication through enable_jupyter_auth, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control ML3-P8

> Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Unprivileged user accounts cannot access their own backups. Privileged user accounts (excluding backup administrator accounts) cannot access backups belonging to other user accounts. Privileged user accounts (excluding backup administrator accounts) cannot access their own backups. Unprivileged accounts are prevented from modifying and deleting backups. Privileged user accounts (excluding backup administrator accounts) are prevented from modifying and deleting backups. Backup administrator accounts are prevented from modifying and deleting backups during their retention period.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The `CloneFromSnapshot` CRD includes a `status.phase` field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in `etcdctl snapshot save` command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to `/etc/kubernetes/tmp` containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the `RecoveryBackupJobBackupRequest` data structure for specifying backup location, protocol, authorization, and database scope, as well as the `RecoveryBackupSchedulesUpdateSpec` for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the allowedBackupLocations parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the restore-provider command with a pgbackrest.conf path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the export command), or REST API (using the /api/scheduler/ endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the keep_uuid option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

